



SiGeRU

Instituto o Escuela:	ESI Buceo
Clase:	3MG
Nombre de Grupo:	BCC Code Corp.
Integrantes:	Francisco Barreto

	Mateo Cortizo Giuliano Crotti
Responsable:	Francisco Barreto
Fecha Avance:	27/07/2026
# Avance:	Primer Avance
Espacio Téc.:	Ciberseguridad
Docente:	Gabriela Borba

Sistema de Gestión de Residuos Urbanos

SiGeRU

Primer AVANCE de Proyecto

Versión 1.0

Historia de revisiones

Fecha	Versión	Descripción	Autor
20/06/2026	1.0	Primer avance del Proyecto, contenido de ciberseguridad.	Francisco Barreto, Mateo Cortizo, Giuliano Crotti

Tabla de contenido

Sistema de Gestión de Residuos Urbanos.....	2
SiGeRU.....	2
Historia de revisiones.....	2
Tabla de contenido.....	3
1. Identificación de amenazas específicas para el sistema SiGeRU.....	4
2. Posibles vulnerabilidades en la infraestructura.....	4
3. Controles de acceso y roles de usuarios.....	4
3.1. Que es un control de acceso.....	4
3.2 ¿Qué tipos de usuarios van a existir en el sistema?.....	5
3.3 Para explicar en clase.....	5
3.4 Tarjetas.....	5
4. Políticas de Contraseñas de BCC Code Corp.....	6
4.1 Requisitos de creación de contraseñas.....	6
4.2 Administración de contraseñas.....	6
4.3 Cambio y actualización.....	6
4.4 Protección de cuentas.....	6
4.5 Almacenamiento seguro.....	6
4.6 Ejemplificación.....	7
5. Políticas y medidas de seguridad.....	7
5.1 Seguridad por capas.....	9
Bibliografía.....	10

1. Identificación de amenazas específicas para el sistema SiGeRU

Las amenazas se centran en la lógica de negocio, protegiendo al sistema contra vectores de ataque directos al código:

- **Inyección SQL (SQLi):** Riesgo crítico de manipulación de la base de datos mediante la inserción de comandos en campos de entrada.
- **Cross-Site Scripting (XSS):** Amenaza de ejecución de código malicioso en navegadores de usuarios al visualizar datos no saneados.
- **Manipulación de Parámetros (IDOR):** Acceso no autorizado a reportes ajenos mediante la modificación de IDs en la URL.

2. Posibles vulnerabilidades en la infraestructura

El despliegue de SiGeRU se basa en una estrategia de desarrollo local distribuido (entornos personales) con despliegue en el servidor local de la Institución para validaciones y entregas formales. Esto genera riesgos específicos:

- **Riesgos de Desarrollo Local:** Exposición accidental de credenciales en archivos de configuración (.env) durante el trabajo en equipos personales y falta de un entorno endurecido (hardening) temprano.
- **Riesgos del Servidor Local ESI:** * Acceso Físico: Vulnerabilidad ante manipulación física del hardware o extracción de dumps de base de datos.
 - **Segmentación:** Dependencia de la red interna de la institución; ante falta de VLAN aislada, el sistema queda expuesto a movimiento lateral.
 - **Gestión de Permisos:** Riesgo de permisos excesivos en el sistema de archivos del servidor multiusuario, facilitando el acceso a archivos de configuración.

****Aclaración**** Un dump es una copia de seguridad completa del estado de una base de datos en un momento específico.

3. Controles de acceso y roles de usuarios

3.1. Que es un control de acceso

Los controles de acceso sirven para saber qué puede hacer cada usuario dentro del sistema. Como hay diferentes tipos de usuarios, cada uno tendrá permisos distintos según las tareas que tenga que hacer. Esto ayuda a proteger la información y evitar cambios no autorizados.

3.2 ¿Qué tipos de usuarios van a existir en el sistema?

Usuarios	Que hacen
Administrador municipal	Gestionar usuarios, contenedores, centros de acopio, vertederos y rutas de recolección.
Cuadrilla de recolección	Consultar rutas asignadas, actualizar el estado de la recolección y reportar incidencias.
Operarios de vertederos o centros de acopio	Registrar información sobre los residuos que se recibieron y consultar.
Vecinos	Hacer reclamos y consultar información.
Invitado	Ver la información sin iniciar sesión

3.3 Para explicar en clase

Un estudiante no tiene las mismas llaves que un docente, y un docente no tiene las mismas llaves que el director. Cada uno puede entrar a ciertos lugares y hacer ciertas cosas, no todas.

En un sistema informático pasa exactamente lo mismo: cada usuario tiene un rol, y ese rol define qué permisos tiene. Esto se llama control de acceso basado en roles. No le damos a todo el mundo las mismas llaves, porque eso sería un riesgo de seguridad enorme (cualquiera podría borrar usuarios, cambiar rutas, etc.).

3.4 Tarjetas

Acción	Rol que lo puede hacer
Eliminar usuario	Administrador
Ver rutas	Cuadrilla de recolección
hacer reclamos	Vecinos
Crear administradores	Administrador

4. Políticas de Contraseñas de BCC Code Corp

Las políticas de contraseñas de **BCC Code Corp** establecen los requisitos mínimos de seguridad que deben cumplir todas las contraseñas utilizadas dentro de los sistemas, aplicaciones y servicios de la empresa, con el objetivo de proteger la información y evitar accesos indebidos.

4.1 Requisitos de creación de contraseñas

Las contraseñas deberán cumplir con los siguientes criterios:

- Tener una longitud mínima de **8 caracteres** (recomendado 12 o más para mayor seguridad).
- Incluir una combinación de:
 - Letras mayúsculas.
 - Letras minúsculas.
 - Números.
 - Caracteres especiales (ejemplo: @, #, \$, %).
- No utilizar información personal fácilmente identificable como nombres, fechas de nacimiento o datos públicos.
- No utilizar contraseñas comunes como "123456", "password" o similares.

4.2 Administración de contraseñas

- Las contraseñas no deberán compartirse entre usuarios.
- Los usuarios serán responsables de mantener la confidencialidad de sus credenciales.
- En caso de sospecha de filtración o acceso no autorizado, la contraseña deberá ser modificada inmediatamente.

4.3 Cambio y actualización

- Las contraseñas podrán ser renovadas periódicamente según las necesidades de seguridad de BCC Code Corp.

4.4 Protección de cuentas

- Luego de 5 intentos fallidos de inicio de sesión, la cuenta podrá bloquearse temporalmente como medida de seguridad.
- Se recomienda implementar autenticación multifactor (MFA) en sistemas críticos.
- Los administradores tendrán permisos especiales para gestionar usuarios y recuperar accesos.

4.5 Almacenamiento seguro

- Las contraseñas nunca deberán almacenarse en texto plano.
- Deben almacenarse utilizando métodos seguros de cifrado o hash.

- El acceso a las credenciales administrativas deberá estar restringido únicamente al personal autorizado.

4.6 Ejemplificación

Una contraseña débil es aquella que resulta fácil de descubrir porque utiliza palabras comunes, datos personales o patrones conocidos.

Esta misma, no tiene porqué que ser una combinación imposible de recordar cómo **X7@kP92#**, ya que puede provocar que el usuario la olvide y tenga que reemplazarla o necesite usar esta misma para muchos sitios, lo cual provocaría un grave problema si es vulnerada.

Ejemplos débiles:

- **12345678** → es una combinación muy utilizada.
- **password123** → usa una palabra común y números predecibles.
- **Juan2005** → contiene información personal fácil de obtener.

Ejemplos fuertes:

- **CafeConSol!27Nube**
- **Tren-Verde-Rio-84!**

Estas contraseñas son más seguras porque combinan letras, números, símbolos y varias palabras.

Una contraseña puede ser al mismo tiempo:

- **Larga:** tiene muchos caracteres.
- **Memorable:** el usuario puede recordarla fácilmente.
- **Difícil de adivinar:** no contiene datos personales ni patrones comunes.

Ejemplo:

LunaCafe-RioVerde-27!

Es fácil de recordar para quien la creó, pero difícil de adivinar para otra persona.

5. Políticas y medidas de seguridad.

Las políticas de seguridad de **BCC Code Corp** establecen las reglas necesarias para proteger la información, los sistemas y los recursos tecnológicos de la empresa. Estas políticas indican qué acciones deben cumplirse, mientras que las medidas de seguridad definen cómo se aplican en la práctica.

La seguridad del sistema se trabaja mediante diferentes capas: **usuario, aplicación, base de datos, servidor y red**. De esta forma, si una capa presenta una vulnerabilidad, las demás ayudan a reducir el impacto.

Política	Medida de aplicación
Proteger el acceso al servidor	Utilizar usuarios individuales, evitar cuentas compartidas y aplicar permisos según el rol de cada integrante.
Reducir servicios expuestos	Cerrar puertos y servicios que no sean necesarios para disminuir posibles puntos de ataque.
Proteger la base de datos	Crear usuarios con permisos limitados y evitar accesos directos innecesarios a la información.
Mantener los sistemas actualizados	Aplicar actualizaciones de seguridad periódicas en servidores, aplicaciones y herramientas utilizadas.
Registrar eventos importantes	Guardar registros (logs) de accesos, errores y actividades relevantes para detectar problemas.
Resguardar la información	Realizar copias de seguridad periódicas y definir una frecuencia de respaldo para evitar pérdida de datos.
Proteger las sesiones de usuarios	Cerrar sesiones luego de períodos de inactividad y controlar los accesos activos.
Proteger el código fuente	Mantener el repositorio con permisos controlados y evitar exponer información sensible dentro del código.

Proteger contraseñas	Utilizar contraseñas seguras, no compartir credenciales y aplicar buenas prácticas de autenticación.
Proteger la red	Utilizar configuraciones seguras, controlar conexiones y limitar accesos externos al sistema.

5.1 Seguridad por capas

La seguridad de un sistema se puede dividir en diferentes capas de protección. Cada capa representa un área donde se pueden aplicar medidas de seguridad para reducir riesgos y proteger la información.

- **Capa de usuario:** Se encarga de controlar el acceso de las personas al sistema. Se aplican usuarios individuales, permisos según el rol y contraseñas seguras para evitar accesos no autorizados.
- **Capa de aplicación:** Protege el funcionamiento del software mediante controles internos. Incluye validación de datos ingresados, manejo seguro de sesiones y restricciones para que cada usuario pueda realizar únicamente las acciones permitidas.
- **Capa de base de datos:** Protege la información almacenada en el sistema mediante controles de acceso, permisos limitados y copias de seguridad para evitar pérdida o modificación no autorizada de datos.
- **Capa de servidor:** Hace referencia al equipo o entorno donde se ejecuta la aplicación. Incluye la configuración del sistema, los servicios necesarios para su funcionamiento y el control del entorno donde se encuentra instalado.
- **Capa de red:** Aunque el sistema funcione localmente, existe comunicación entre componentes (por ejemplo aplicación y base de datos). Esta capa contempla la protección de conexiones, accesos y configuraciones de comunicación del sistema.

Bibliografía

International Organization for Standardization. (2022). *ISO/IEC 27001:2022 Information security, cybersecurity and privacy protection — Information security management systems*. <https://www.iso.org/standard/27001>

International Organization for Standardization. (2022). *ISO/IEC 27002:2022 Information security, cybersecurity and privacy protection — Information security controls*. <https://www.iso.org/standard/75652.html>

Mozilla Foundation. (s. f.). *MDN Web Docs: Web security*. <https://developer.mozilla.org/en-US/docs/Web/Security>

National Institute of Standards and Technology. (2020). *Digital identity guidelines: Authentication and lifecycle management* (NIST Special Publication 800-63B). U.S. Department of Commerce. <https://pages.nist.gov/800-63-3/sp800-63b.html>

National Institute of Standards and Technology. (2024). *Cybersecurity Framework (CSF) 2.0*. U.S. Department of Commerce. <https://www.nist.gov/cyberframework>

Oracle Corporation. (s. f.). *MySQL 8.0 Reference Manual*. <https://dev.mysql.com/doc/>

OWASP Foundation. (2021). *OWASP Top 10: The ten most critical web application security risks*. <https://owasp.org/www-project-top-ten/>

Pressman, R. S., & Maxim, B. R. (2020). *Ingeniería del software: Un enfoque práctico* (9.ª ed.). McGraw-Hill.

Sommerville, I. (2016). *Ingeniería del software* (10.ª ed.). Pearson.

Stallings, W., & Brown, L. (2018). *Computer security: Principles and practice* (4th ed.). Pearson.